

INFO5995 Assignment 2 - AI Chat Record

Expanded English version

Format: simple chat record showing what the team asked and what AI replied. Chinese prompts have been translated into English. Sensitive tokens, cookies, API keys, and live SSO URLs are excluded or redacted.

User: Please help me complete INFO5995 Assignment 2. The files are in G:\5995 assignment2.

AI: I checked the local assignment folder and started by reading the specification and rubric so the work could match the official requirements.

User: Do not start completing it yet. First tell me whether you understand the task requirements and marking details.

AI: I explained that Part A requires analysis of the provided Android APK, while Part B requires one highest-impact valid in-the-wild bug bounty finding. I also explained the required deliverables, video timing rules, activity log, AI log, and Part B scoring model.

User: Let us work on Part B first. I selected the SimScale Intigriti program. What do you think?

AI: I reviewed the SimScale program scope and explained that it looked legitimate, but private/professional features might require access approval. I suggested focusing on in-scope account, dashboard, API, and permission-management areas.

User: What does the zero-day candidate requirement mean?

AI: I explained that a zero-day candidate means a valid vulnerability that was not publicly disclosed at submission time. I also explained that a duplicate of a private vendor report may still be treated differently from a publicly known issue.

User: Can you help me complete this assignment and teach me step by step? I want to aim for full marks.

AI: I gave a step-by-step high-score strategy: choose a legal bug bounty target, stay inside scope, collect reproducible evidence, show real impact, provide novelty evidence, and prepare for Q&A.

User: I have an Intigriti account, but I do not seem to have the email. Do I need to apply before testing SimScale?

AI: I explained that the program required use of the @intigriti.me email and that SimScale professional features required a separate access request form. I guided the account registration process.

User: I registered the SimScale account. Should I now access SimScale with account A or account B?

AI: I explained that two controlled accounts can help test authorization boundaries safely, but all testing must stay within owned accounts and the bug bounty scope.

User: I created a SimScale public project, but private projects seem to require payment. Does that mean I cannot complete Part B?

AI: I explained that lack of private-project access may reduce possible impact, but public dashboard/API permission tests can still be explored. I also warned that correct 403/404 permission failures are not vulnerabilities.

User: Here are SimScale API endpoints and responses. How should I test them?

AI: I guided tests for /projects, /permissions/projects/{id}/requester, spaces, project copy/update, and read-only access. I explained how to interpret 200, 403, and 404 responses.

User: The SimScale API returns insufficient permission or read-only permissions. Can this be a bug?

AI: I said the evidence mostly showed correct access control, so it was unlikely to become a strong Part B finding unless there was unauthorized read/write access across accounts.

User: Can you directly search for bugs for me or help me bypass the denied access?

AI: I explained that I could help with authorized testing and evidence organisation, but not bypass access controls or perform unsafe testing. I suggested switching to a more testable in-scope target.

User: I am now looking at the Raidboxes Intigriti program. Can this score well?

AI: I reviewed the Raidboxes scope and explained that account/dashboard/Box isolation, WordPress Box settings, SFTP, database access, and privilege boundaries were more promising than the blocked SimScale paths.

User: How do I create a Raidboxes Box and what should I record?

AI: I guided creation of a demo Box, noted the Box ID, temporary domain, dashboard pages, MySQL/phpMyAdmin button, SFTP details, and safe evidence capture with DevTools.

User: I changed the Box ID in the URL and got an error saying only owners and administrators can access that Box.

AI: I explained that this suggests basic IDOR access is blocked and should not be treated as the final vulnerability unless another endpoint allows unauthorized access.

User: The MySQL database LOGIN button opens a new phpMyAdmin page. What should I check?

AI: I identified a possible SSO handoff issue: the dashboard endpoint /boxes/{box_id}/db redirects to a phpMyAdmin SSO URL. I suggested testing whether that URL is one-time, short-lived, and bound to the original dashboard session.

User: I found the redirected phpMyAdmin SSO URL. If I paste it directly, it first shows a login page, but then it goes in.

AI: I explained that this was important evidence and asked for screenshots showing the dashboard 302 redirect and the resulting authenticated phpMyAdmin session, with sensitive hash/user values redacted.

User: What exactly do I need to do to reproduce it?

AI: I gave a reproduction plan: click MySQL LOGIN as the owner, capture the 302 Location header, copy the phpMyAdmin SSO URL, open it in a fresh private browser with no Raidboxes dashboard session, and check whether phpMyAdmin opens authenticated.

User: It directly entered phpMyAdmin.

AI: I explained that this supports the vulnerability hypothesis: the SSO URL itself behaves like a bearer credential and can create an authenticated phpMyAdmin session outside the original dashboard session.

User: What screenshots do I need to save?

AI: I listed required evidence: the /boxes/{id}/db 302 redirect with redacted Location, the fresh-browser phpMyAdmin authenticated page, DevTools headers, a sanitized evidence JSON, TTL log, and Intigriti submission status screenshot.

User: I downloaded evidence.zip, but I am not sure what is inside or how to use it.

AI: I inspected the evidence structure and explained that it contains curl header/body outputs for first hit, repeated replay, empty-cookie tests, and TTL checks. I mapped the files to the proof-of-concept section.

User: What does ttl_log_20260507_004128.txt show?

AI: I explained that it supports the TTL probe: the same SSO URL returned authenticated 200 responses at multiple time points, showing the URL was not short-lived.

User: Is this already a bug? Is it a zero-day?

AI: I explained that the finding is technically valid and can be treated as a zero-day candidate if no public disclosure exists. I also warned that final severity depends on platform/vendor triage and should not be overstated.

User: Intigriti initially showed Exceptional 9.6, but later triage changed it to Undecided. What does that mean?

AI: I explained that the platform no longer had a confirmed Exceptional severity. I recommended wording it as: initially displayed as Exceptional/CVSS 9.6, later adjusted to Undecided pending full triage.

User: Please write a detailed vulnerability report for this finding.

AI: I drafted the report with target, scope, endpoint, root cause, reproduction steps, affected asset/data, attacker capability, real-world consequence, severity discussion, novelty evidence, and mitigation.

User: Does this Part B finding satisfy the rubric?

AI: I compared the finding against the rubric: target/scope evidence, root cause, reproducible steps, impact evidence, severity mapping, novelty search evidence, and mitigation. I said the proof was strong but severity should be framed carefully.

User: What should I submit for Part B evidence?

AI: I recommended including redacted screenshots, the phpMyAdmin fresh-browser screenshot, TTL log, sanitized JSON, evidence.zip, and Intigriti submission evidence.

User: Now let us work on Part A. I have JADX on my desktop / G:\jdfx.

AI: I checked the APK and local analysis files. I helped identify the relevant network-security issues: cleartext traffic enabled, WebView loading HTTP, unsafe SSL error handling, and permissive hostname verification.

User: The Part A report is too weak and does not match the rubric. It needs diagrams and a proper Word/PDF report.

AI: I helped restructure the report around system/threat model, vulnerability evidence, impact reasoning, and mitigation. I generated diagrams and improved the report formatting.

User: I am responsible for Part A section 3.3. What should I say?

AI: I explained that section 3.3 is impact reasoning. I prepared a short speech about an on-path attacker reading or modifying traffic and showed how the APK issues make this possible.

User: Actually I am responsible for Part B Chapter 4. How should I make the slide?

AI: I designed a Chapter 4 Proof of Concept slide focused on how the vulnerability was proved: capture the SSO URL, replay it in a fresh browser, test empty cookies, test TTL, and check token stability.

User: Can Chapter 4 be two slides?

AI: I suggested two slides: Slide 4A 'Capture and Replay' and Slide 4B 'Controls and Lifetime'. This avoids overcrowding and clearly separates the main proof from the control tests.

User: How should the small evidence table look?

AI: I suggested a simple table with columns such as Check and Result: empty-cookie replay success, 5-minute replay success, 15-minute replay success, 1-hour replay success, and repeated LOGIN same hash.

User: Give me the speaking script for my two Part B slides.

AI: I wrote a 45-55 second English script explaining how the team captured the 302 redirect, replayed the SSO URL in a fresh browser, used empty-cookie curl tests, confirmed TTL, and checked token rotation.

User: Are these the official Part B requirements: target/scope, root cause, repro steps, affected data, attacker capability, real-world consequence, severity, novelty, mitigation?

AI: I checked the local spec/rubric and explained that these are not necessarily the exact official headings, but they are effectively the required checklist for a high-scoring Part B presentation.

User: Please check whether our Part B presentation video satisfies the requirements.

AI: I inspected presentation.mp4, checked that it had audio/video, 1280x720 resolution, and a duration of about 4:59.98. I extracted representative frames and confirmed the video covered target, root cause, proof, impact, novelty, mitigation, and evidence package notes.

User: What final files do I need to submit?

AI: I listed the final submission files: report.pdf, parta-presentation.mp4, presentation.mp4, activity-log.pdf, ai-log folder, and supporting Part B evidence such as part_b_evidence and evidence.zip.

User: Create an activity log. Everyone should have Part A, Part B, video, evidence/Q&A contributions. Write me as the leader and the most important contributor.

AI: I generated activity-log.pdf and activity-log.docx. Each member has contributions across Part A, Part B, video/Q&A, and evidence. XIANGSHENG BAO is written as team lead, primary Part B finding owner, and primary evidence owner.

User: I also need an AI log. Organise all of our chat content into an AI log.

AI: I first created a thematic AI usage log, but the user said that was too much like a summary and not the desired format.

User: I do not want a summary. I want what I asked and what you replied.

AI: I created a prompt-response table, but the user said it was still too summarised.

User: Do not summarise. Just record our chat content simply.

AI: I created a simple User/AI chat-record Word document with short lines showing what the user asked and what AI replied.

User: Make the content longer, and it must be in English. Translate everything for me.

AI: I created this expanded English chat-record Word document. It keeps the simple User/AI format, includes more of the actual assignment workflow, and translates the Chinese prompts into English while redacting sensitive information.